SOC2 For Solo Founders Cheat Sheet

6 printable pages of the actual SOC2 controls you need to ship in 90 days. Pin the 1-pager to your wall. Use the tracker every week. Stop scrolling Twitter and start shipping.

Page 1 -- The Five Controls (wall poster)

The only five SOC2 controls a solo founder needs to ship Type 1 in 90 days.

- 1. **Access control.** SSO on every system. MFA on every account. Offboarding checklist that disables access within 24 hours of termination.
- 2. **Change management.** Every code change is PR-reviewed, tested, and has a CHANGELOG entry.
- 3. **Incident response.** A 1-page runbook: detect, contain, eradicate, recover, post-mortem.
- 4. **Vendor management.** Spreadsheet of every third party that touches customer data, with security review status.
- 5. **Encryption + backup.** TLS everywhere. DB encrypted at rest. Daily backups with a monthly restore drill.

If you have these five working, you can pass Type 1. Everything else is decoration.

Page 2 -- The 90-Day Calendar

Week	Action	Owner	Done?
1	Pick platform (Vanta/Drata) + auditor	Founder	[ ]
2	Sign contracts, kick off onboarding	Founder	[ ]
3-4	Write 5 policies from templates	Founder	[ ]
5-6	Integrate SSO, code repo, AWS, HR, ticketing	Engineer	[ ]
7-8	Fill vendor reviews, run background checks	Founder	[ ]
9	Run first internal audit (platform does this)	Founder	[ ]
10-12	External audit, address findings	Auditor	[ ]

The hardest week is week 6. That's when the integrations break and you have to debug SSO at midnight. Survive it. Everything after is downhill.

Page 3 -- Weekly Compliance Checklist

Print this. Every Friday, walk through it. 15 minutes. That's the whole program.

```
Friday Compliance Check (15 min)
--------------------------------
[ ] Any new vendors this week? Add to vendor list + start DPA.
[ ] Any new employees? SSO + MFA + background check on day 1.
[ ] Any terminations this week? Offboarding checklist run within 24h?
[ ] Any new production systems? Encryption at rest + in transit verified?
[ ] Any new public endpoints? Pen test scheduled within 30 days?
[ ] Any code merged without PR review? Roll it back.
[ ] Any customer data in a new tool? DPA in place before processing?
[ ] Backups ran successfully this week? (check email report)
[ ] Monthly backup restore test? (only on last Friday of month)
[ ] Quarterly access review? (only on last Friday of quarter)
```

Done. That's the whole Friday ritual. Auditors love seeing this checklist completed weekly.

Page 4 -- The Offboarding Checklist (run within 24 hours of any termination)

```
Offboarding (24h SLA)
---------------------
[ ] Disable SSO account (Google Workspace / Okta)
[ ] Remove from code repos (GitHub org)
[ ] Remove from cloud consoles (AWS IAM, GCP, Cloudflare)
[ ] Remove from ticketing (Linear, Jira, Notion)
[ ] Remove from monitoring (Datadog, PagerDuty)
[ ] Remove from comms (Slack, email, Zoom)
[ ] Rotate any API keys the person had access to
[ ] Recover company hardware (laptop, phone, YubiKey)
[ ] Document completion in HR system (date + initials)
```

Why this is the most-checked audit item: every breach that ever made the news started with "we forgot to disable their account." Run this checklist the same day. Don't wait.

Page 5 -- The Vendor Review (one per vendor, ~10 min each)

```
Vendor Security Review
----------------------
Vendor:          _____________________________
Data they access: _____________________  [PII | No PII | Metadata only]
SOC2 or equivalent?   [ ] Yes  [ ] No  [ ] N/A
DPA signed?           [ ] Yes  [ ] No
Last reviewed:    _____ (date)
Reviewer:         _____________________________

If "No PII" and "N/A" on SOC2 -> minimal risk, file and move on.
If "PII" and "No" on SOC2 -> STOP, don't integrate until they have one.
If "PII" and "Yes" on SOC2 -> save their SOC2 report in vendor folder.
```

The minimum vendor list for a typical B2B SaaS: AWS, Stripe, your database host, your email tool, your analytics tool, your error-tracking tool, your AI provider (OpenAI/Anthropic), your customer support tool. That's 8-15 vendors. Budget 3-4 hours to fill in the whole spreadsheet.

Page 6 -- The Incident Response 1-Pager (laminate this)

```
INCIDENT RESPONSE -- 1 page
---------------------------
```

- 1. DETECT Customer report, monitoring alert, or team member
  Time-stamp the report. Create a #inc channel.
- 2. CONTAIN Stop the bleeding. Disable the affected system
  or feature. Do not delete logs.
- 3. ERADICATE Remove the root cause. Patch the vuln, revoke
  the token, delete the malicious file.
- 4. RECOVER Restore from backup if needed. Verify the fix

with a test. Re-enable the system.

- 5. NOTIFY 72h to regulator if PII breach. ASAP to customers. Use the breach template.
- 6. POST-MORTEM Within 5 business days. Blameless. What broke, what worked, what to change. Publish internally.

Incident Commander: _____ (probably you)

Backup IC: _____

Regulator contact: _____ (your local DPA)

Customer comms: _____ (your support email)

If in doubt, default to over-communicating. Customers forgive

honest mistakes. They don't forgive silence.

```

**This is the only page you actually need during an incident.** Keep it on your desk. The other 5 pages are for the Friday ritual.
```